

Postmarket Cybersecurity Plan

Grounded in: Modeled on a large connected-device maker (e.g., Medtronic)

Basis: FDA Postmarket Cybersecurity guidance.

Basis	Modeled on a large connected-device maker's PSIRT practice (e.g., Medtronic)
Regulatory	§524B(b)(1); FDA Postmarket Cybersecurity guidance (2016)

1. Monitoring

- SBOM→CVE matching (daily), CISA KEV, vendor PSIRT feeds, researcher reports via CVD intake.

2. Assessment

Score exploitability × patient-harm; classify controlled vs uncontrolled risk per FDA postmarket guidance (CVSS + clinical impact).

3. Remediation & notification

Severity-based patch SLAs; signed OTA / staged deployment with rollback; customer security bulletins; ≤ 30-day notification for uncontrolled risk.

4. Reporting & metrics

Metric	Example target
Mean time to remediate (critical)	≤ 30 days
% fleet on supported version	≥ 95%
Open critical vulnerabilities	0

Sources (public)

- Medtronic — publicly documented Product Security / coordinated vulnerability disclosure (PSIRT) program.
- FDA — Postmarket Management of Cybersecurity in Medical Devices (2016); §524B(b)(1).
- AAMI TIR97 (postmarket security); CISA ICS medical advisory coordination.